PEP-VOCABULARY — SECURITY CLOUD

# 安全修复报告

■ 7 项扫描发现与单篇删除追加修复均已验证

版本 2.18.1
扫描 466188b
代码 a2758c2

| 7 / 7 | 1 / 3 / 3 | 598 / 598 |
| --- | --- | --- |
| 扫描发现已修复并验证 | 高 / 中 / 低风险 | 全库测试通过 |

## 发现与修复

风险级别沿用 Cloud 扫描

| 编号 / 级别 | 问题与影响 | 修复边界 |
| --- | --- | --- |
| 01 高 | **发布产物脱离审阅版本**<br>忽略目录中的旧 Worker / 客户端代码可进入发布包。 | 打包入口同次清理并重建产物，再校验和归档<br>fixed · 已验证 |
| 02 中 | **基准工具执行历史源码**<br>Git ref 内容经转译和 import 后获得本机 Node 权限。 | 只接受已审查的完整 SHA；其他 ref 直接拒绝<br>fixed · 已验证 |
| 03 中 | **学习日志墓碑持续增长**<br>删后保留行绕过活跃事件上限，任意日期删除也会分配行。 | 100,000 事件 / 64 MiB 计量预算；SQL 原子守卫<br>fixed · 已验证 |
| 04 中 | **DOCX 嵌套段落放大正文**<br>段落递归重复收集后代文本，可阻塞浏览器主线程。 | 结构预检与单遍提取，阻止重复正文放大<br>fixed · 已验证 |
| 05 低 | **公开来源清单含私有信息**<br>私有材料名称、Drive 标识与分享链接进入公开来源输出。 | 生成器与两份公开清单同步移除私有入口<br>fixed · 已验证 |
| 06 低 | **代理指引调用未锁定工具**<br>vendored 技能建议 npx 获取并执行未锁定的 svgo。 | 移除未锁定执行示例，保留安全优化指引<br>fixed · 已验证 |
| 07 低 | **清除后文章仍可读和导出**<br>已挂载阅读页保留文章状态，清除成功后仍显示旧内容。 | 提交后广播代次，立即移除文章与导出入口<br>fixed · 已验证 |

扫描记录
LATEST / COMPLETED

北京时间 12:54 启动 / 13:19 完成
扫描目标 466188b；发布 2.18.1，代码提交 a2758c2。七项扫描发现及追加单篇删除问题完成触发、正常对照、回归与独立复核；发布包和本地 Worker / D1 检查单独核验。

ENFORCEMENT / EVIDENCE

# 边界与验证

02

将保护收敛到共享入口，覆盖同一路径的别名、并发和迟到状态。

**构建与工具** 代码 / Git ref / dist → 全新构建 / 审查 SHA → 执行 / 发布包

发布沿用清理、超时和结构校验；基准仅允许已审查的完整 SHA，拒绝任意 ref。

**导入与日志** DOCX / 事件 / 日期 → 解析限额 / SQL 预算 → 正文 / D1 行

XML 结构预检配合单遍提取。日志预算包含墓碑，满额时整批原子拒绝；删除正文后保留 ID 和隐私代次。

**本机清除** 清除操作 / 缓存视图 → 提交后代次通知 → 展示 / 导出 / 迟到任务

个人库清除后通知当前页与同源标签页，撤销缓存正文、个人列表、导出入口与导入状态，阻止迟到保存。

## 验证记录

攻击触发 / 正常对照 / 仓库检查

01 **原始触发与变体** 通过

发布 / 基准 3 项回归；日志定向 24 项覆盖 100k 行、UTF-8、迁移和满额删除。DOCX 深度、输出、段落、标记和坏 XML 均拒绝。

02 **正常行为与浏览器对照** 通过

默认与既有 reading 基线一致；普通 / Strict DOCX、表格、文本框、CDATA 和实体保留。原清空流程通过双页浏览器验证；追加单删的跨页、漏通知补漏、旧库升级与导出有行为回归。

03 **仓库检查、运行时与独立复核** 598 / 598

npm run test:unit 598/598；typecheck、lint、audit:prod 通过（生产依赖 0 漏洞）。独立复核完成；真实 workerd / D1 覆盖迁移 0009、409 整批回滚与正常日志。

发布门禁：bash scripts/package-site.sh <archive> 从干净已提交源码强制重建、产物校验与归档通过；npm run test:runtime 通过。数据审计：12 套教材 / 19 项来源 / 4,681 条词条，已有声明缺口保持。Chromium 156 页面异常 0。

RESOURCE LIMITS / USER EXPERIENCE

# 资源与使用体验 03

本次优先修复可复现的资源消耗与旧状态问题，保留正常学习路径。

A **DOCX 导入** 响应性

结构预检与单遍有界提取限制 XML 深度、元素、段落和累计输出。正常文档保留段落、表格及文本框内容；过限与畸形输入明确拒绝。

B **学习日志** 共享容量

每账号最多 100,000 条事件（含墓碑），64 MiB 计量预算（含文字与预留行开销）。SQL 触发器原子守卫；满额整批不写入，删除释放正文并保留 ID 与隐私代次。

C **个人文章清除** 数据可见性

整库清空后重置阅读状态；单篇删除按 ID 失效正文、目录与导出，保留无关导入草稿。保存核对删除墓碑，导出重新读取存储；漏通知补漏与迟到任务均有回归。

Chromium 156 · 80 层嵌套样本 · 输出字符数

800,158 → 10,000

修复前 800,158

修复后 10,000

10,000 原字符：旧提取重复累积至 800,158 字符，修复后为 10,000 字符。这里记录单个构造样本的输出长度，整站性能未据此估算。

## 本次交付

### 代码与补丁

发布 2.18.1；代码 a2758c2。基础安全与 bug 修复归入补丁版本，成组功能与重大质量改进才升次版本。

### 验证与迁移

598 项全库回归、实际打包、本地 Worker / D1 与独立复核。新增日志预算迁移及个人库 v3，保留正文、学习备份和稳定词条 ID。

### 图文报告

本次扫描、修复边界与真实验证结果；保留可编辑 HTML、PDF 与逐页 PNG。

验证与处理范围

旧页面需刷新以使用新版删除与导出保护。追加单篇删除的实际浏览器复测受托管预览中继超时限制，已完成行为回归；原 7 项 Chromium 验证可复用。GitHub 与 Sites 发布状态分别核实；Drive 分享与 Git 历史未改动，Cloud 原扫描状态未关闭。